

RISK REGISTER

Potential issues requiring verification during review and execution.

No application source was available, so none of the items below is a confirmed defect. Each is a potential risk area requiring verification during code review or execution.

BUG-01 - Session may remain active after logout

Description: The logout operation may clear only the browser state while leaving a server-side session or bearer token valid.

Severity: Critical

Reason / Impact: A copied token could continue to access task data after logout.

Related Area: Authentication and session handling

BUG-02 - Task ownership may not be checked on every endpoint

Description: A task endpoint may trust a task ID or user ID supplied by the client instead of checking ownership on the server.

Severity: Critical

Reason / Impact: User B could read, edit, or delete User A's tasks through an IDOR-style request.

Related Area: Task API authorization

BUG-03 - Password handling may be unsafe

Description: Passwords may use weak hashing, appear in logs, or be accepted without a minimum-strength rule.

Severity: Critical

Reason / Impact: A database or log leak could expose user accounts.

Related Area: Registration and login

BUG-04 - API validation may be weaker than form validation

Description: The browser may reject bad values while the server accepts direct requests with empty, oversized, or wrong-type fields.

Severity: Major

Reason / Impact: Invalid records or malicious values could be stored by bypassing the UI.

Related Area: Server-side validation

BUG-05 - Repeated create requests may create duplicate tasks

Description: A double click or network retry may be processed as multiple create operations.

Severity: Major

Reason / Impact: Users may receive duplicate records, especially when the first response is delayed.

Related Area: Create task and request idempotency

RISK REGISTER

Potential issues requiring verification during review and execution.

BUG-06 - Delete may update the UI before persistence succeeds

Description: The client may remove a row immediately and ignore a failed database delete.

Severity: Major

Reason / Impact: The task appears deleted until refresh, then returns, which can lead to incorrect user decisions.

Related Area: Delete flow and error handling

BUG-07 - Invalid IDs may cause an unhandled server error

Description: Malformed or nonexistent task IDs may reach a database query without validation or a not-found branch.

Severity: Major

Reason / Impact: A normal bad request could produce a 500 error or expose database details.

Related Area: Task routes and input validation

BUG-08 - Stored task text may not be output-encoded

Description: Task titles may be rendered as HTML instead of text.

Severity: Major

Reason / Impact: A malicious title could execute stored XSS when the task list is opened.

Related Area: Task display and frontend rendering

BUG-09 - Concurrent edits may overwrite newer data

Description: Two updates may be accepted without a version check or last-write rule.

Severity: Major

Reason / Impact: One user's newer change can be silently lost when requests finish out of order.

Related Area: Edit task and database consistency

BUG-10 - Login errors may reveal registered accounts

Description: The response or timing for an unknown email may differ from the response for a wrong password.

Severity: Minor

Reason / Impact: Attackers could enumerate valid accounts and target them with password attacks.

Related Area: Login error handling and rate limiting